

HygienePrio: Cyber-Hygiene Signal Augmentation for EPSS-Weighted Vulnerability Prioritization

Harshavardhan Malla Independent Researcher

Abstract—Capacity-constrained vulnerability remediation teams must decide which (host, CVE) pairs to patch within each maintenance window, yet the dominant public triage signal — the Exploit Prediction Scoring System (EPSS) — is asset-agnostic by design: it estimates per-CVE exploit likelihood without regard to whether the affected host is actively managed, has high patch debt, or is exposed through privileged Active Directory (AD) relationships. Prior work (VulnPrio, Paper 1) found that augmenting EPSS with CVE-level asset criticality and endpoint exposure features did not improve prioritization over the EPSS baseline on a synthetic government-shaped fleet, suggesting that the missing signal is host-level hygiene posture rather than additional CVE-level features. We present HygienePrio, a scoring framework that integrates a Hygiene Risk Score (HRS) — capturing patch posture, AD exposure state, and telemetry freshness derived from a HygieneBench-style synthetic fleet — into an EPSS-weighted (host, CVE) pair prioritization scorer with an explicit interaction term. In a pre-registered synthetic evaluation across 25 fleet seeds (30 total; 5 held out for weight calibration), HygienePrio achieves a mean Precision@50 of 0.509 compared with EPSS-only’s 0.202 — approximately 31 percentage-point improvement under capacity-constrained schedules (synthetic evaluation only; see §9 for scope limitations). Patch posture emerges as the dominant hygiene dimension in ablation experiments (~20 pp drop at P@50 when removed), consistent with the hypothesis that residual patch debt is a stronger host-level differentiator than AD exposure breadth or telemetry staleness alone. To our knowledge, HygienePrio is the first scorer to jointly optimize per-CVE exploit likelihood and host-level hygiene posture for remediation ordering in a reproducible, open evaluation framework. All claims are bounded to the synthetic evaluation context; generalization to real enterprise fleets requires external validation not performed here.

Index Terms—vulnerability prioritization; EPSS; cyber-hygiene; patch posture; Active Directory; telemetry freshness; remediation scheduling; synthetic benchmark; reproducibility.

I. Introduction

Public-sector and enterprise endpoint fleets accumulate disclosed vulnerabilities faster than operations teams can remediate them within constrained maintenance windows. The practical triage question is not which vulnerabilities are inherently severe but which (host, CVE) pairs should receive the next unit of limited remediation capacity — a distinction that requires combining exploit-likelihood signals with knowledge of which hosts are most exposed and least well-maintained.

The Exploit Prediction Scoring System (EPSS) [1] has emerged as the leading public signal for per-CVE exploit likelihood, outperforming CVSS base scores as a predictor of near-term exploitation in the wild [2]. EPSS is incorpo-

rated into risk-based vulnerability management (RBVM) tools, CISA guidance, and remediation policy frameworks. However, EPSS is asset-agnostic by design: it assigns a single probability score to a CVE regardless of whether the vulnerable host is a freshly-telemetered, heavily-patched workstation or an unmanaged endpoint with stale patch data and over-privileged AD group memberships.

Intuitively, a CVE with moderate EPSS on a host that has gone 21 days without telemetry, carries 40% unpatched CVE debt, and is accessible from domain-privileged accounts represents a materially different risk than the same CVE on a well-maintained host with fresh telemetry and minimal AD exposure. Yet EPSS rankings treat both identically. Host-level hygiene posture — the aggregate state of patch compliance, identity and access management hygiene, and telemetry coverage — is a natural complement to exploit-likelihood scoring.

Prior work directly relevant to this problem is VulnPrio [3] (referred to throughout as Paper 1), which built a reproducible benchmark for (host, CVE) pair prioritization on a synthetic government-shaped fleet (EEHDA) and evaluated 13 strategies combining EPSS, CVSS, KEV membership, asset criticality, and endpoint exposure signals. Paper 1’s central null finding was that the proposed multi-factor model was statistically indistinguishable from the EPSS-only baseline: inter-strategy differences fell within seed-to-seed variation, and no CVE-level augmentation strategy materially outperformed EPSS. Paper 1 concluded that this result exposed capacity-driven and base-rate trade-offs and provided a falsifiable benchmark on which calibrated studies could build — explicitly framing the result as a foundation for future work rather than an endpoint.

Separately, HygieneBench [4] (Paper 3) introduced a reproducible benchmark for cyber-hygiene anomaly detection on a synthetic fleet covering Active Directory identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness. HygieneBench’s primary finding was that 86.2% of evaluated (condition, task, method) configurations fail to outperform a rule baseline, but that patch-vulnerability hygiene (Task T5, +0.210 average precision over rule for OCSVM) and group-membership drift (Task T2, +0.185 AP for temporal z-score) are exceptions where structured ML methods add meaningful signal.

The central hypothesis of this paper is that the signal missing from Paper 1’s multi-factor model was not additional CVE-level features but host-level hygiene pos-

ture: patch debt, AD privilege exposure, and telemetry freshness. HygieneBench demonstrated that these dimensions carry discriminative structure detectable from the synthetic fleet telemetry. HygienePrio operationalizes this hypothesis by constructing a Hygiene Risk Score (HRS) from HygieneBench-style host telemetry and integrating it into an EPSS-weighted (host, CVE) scorer via an additive combination with an explicit interaction term.

A. Contributions

This paper makes the following contributions:

- C1 — HygienePrio scorer: A four-component weighted scoring function $S(h, c) = \alpha \times \text{EPSS}(c) + \beta \times \text{HRS}(h) + \gamma \times \text{KEV_recency}(c) + \delta \times (\text{EPSS}(c) \times \text{HRS}(h))$ that integrates host-level hygiene posture with per-CVE exploit likelihood in a principled, interpretable form.
- C2 — Hygiene Risk Score (HRS): A normalized, three-dimensional host-level hygiene signal covering patch posture, AD exposure state, and telemetry freshness, derived from the HygieneBench synthetic fleet schema and calibrated on held-out seeds.
- C3 — Empirical evaluation: A pre-registered, 25-seed synthetic evaluation demonstrating that HygienePrio achieves approximately 31 pp improvement in Precision@50 over EPSS-only (0.509 vs. 0.202; non-overlapping BCa 95% CIs; synthetic evaluation), with patch posture as the dominant HRS dimension (~ 20 pp ablation drop) and AD exposure as a substantial secondary contributor (~ 9 pp).
- C4 — Cross-paper synthesis: An explicit cross-paper analysis connecting Paper 1’s null result (CVE-level features insufficient), Paper 3’s positive hygiene-detection signal (T5 patch hygiene and T2 AD drift), and HygienePrio’s positive prioritization result, providing a coherent research narrative about where hygiene signals add value.

B. Paper Organization

Section 2 reviews background and related work. Section 3 formalizes the problem. Section 4 describes the synthetic dataset and fleet. Section 5 presents the HygienePrio methodology. Section 6 describes the experimental setup. Section 7 reports results. Section 8 discusses findings, limitations, and connections to prior papers. Section 9 addresses threats to validity. Section 11 concludes.

II. Background and Related Work

A. EPSS and Exploit-Likelihood-Based Prioritization

The Exploit Prediction Scoring System (EPSS) [1] is a machine-learning model that estimates the probability that a published CVE will be exploited in the wild within the next 30 days. EPSS v3 uses $\sim 1,500$ features drawn from CVE descriptors, NVD metadata, and threat intelligence feeds, and produces daily probability scores for all published CVEs. Empirical evaluations [2] have

shown EPSS substantially outperforms CVSS base scores as a predictor of near-term exploitation: CVEs in the top decile of EPSS account for a disproportionate fraction of observed exploitation events. EPSS is now integrated into CISA’s vulnerability prioritization guidance and is used by numerous RBVM vendors.

CISA’s Known Exploited Vulnerabilities (KEV) catalog [5] is a complementary signal: it lists CVEs confirmed to have been exploited in the wild, with mandated remediation deadlines for federal agencies under BOD 22-01 [6]. KEV membership provides strong prioritization signal but covers only a small fraction of the CVE backlog ($\sim 15,000$ of the 200,000+ published CVEs as of 2026). Prior work has studied optimal combined use of EPSS and KEV [3], generally finding that KEV provides a high-precision but low-recall prioritization set, while EPSS provides broader coverage at reduced precision.

The asset-agnostic limitation. A structural limitation of both EPSS and KEV is that they are CVE-level signals: they score a vulnerability, not a (vulnerability, host) pair. For remediation scheduling, the unit of action is the pair: patching CVE-X on Host-A is a distinct action from patching CVE-X on Host-B, with different operational cost, risk reduction, and scheduling feasibility. EPSS provides no signal about which host carrying a given CVE should be remediated first.

B. CVE-Level Host-Context Augmentation

Prior academic work has attempted to incorporate host context into EPSS-based prioritization. Asset criticality models weight CVE severity by the business criticality of the affected host, producing host-adjusted scores. Exposure models incorporate network reachability, service exposure, and lateral movement risk. Commercial RBVM tools (Tenable Lumin, Qualys TruRisk, Rapid7 InsightVM) combine such signals proprietarily, but their scoring methods are not published and results are not independently reproducible.

Paper 1 (VulnPrio) [3] is the closest public predecessor to HygienePrio. It built an open, reproducible benchmark for (host, CVE) pair prioritization on a synthetic government fleet (EEHDA), evaluating 13 strategies combining EPSS, CVSS, KEV, asset criticality, endpoint exposure, and multi-factor composite scores across 30 seeds. The central finding was null: the proposed multi-factor model was statistically indistinguishable from EPSS-only on the primary metric (expected exploited host-days, EHD), with all inter-strategy differences falling within seed-to-seed variation. Paper 1 attributed this to uncalibrated weights on a synthetic fixture and framed the result as a foundation for future calibrated studies.

Differentiating HygienePrio from Paper 1. Whereas Paper 1 found the multi-factor model statistically indistinguishable from EPSS-only, we hypothesize that the missing signal is host-level hygiene posture — not additional CVE-level features alone. Paper 1’s augmentation features (asset criticality, endpoint exposure, KEV flags) are all

CVE-level or static host-role features. HygienePrio adds dynamic, telemetry-derived hygiene signals: how much patch debt is currently outstanding on this specific host, how exposed this host is through AD group memberships and privileged accounts, and how recently this host has reported telemetry. These are fundamentally different in kind from asset criticality scores and network exposure flags.

C. Cyber-Hygiene Benchmarks and Anomaly Detection

HygieneBench (Paper 3) [4] introduced the first open benchmark for cyber-hygiene anomaly detection covering AD identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness. Its evaluation of eight detection methods across 12 anomaly classes and seven tasks found that 86.2% of (condition, task, method) configurations fail to outperform a rule baseline, but identified task T5 (patch-vulnerability hygiene) and T2 (group-membership drift) as exception zones where structured methods add meaningful signal. HygienePrio draws on the HygieneBench schema as the source of HRS features and inherits its fleet generation logic.

Anomaly detection for hygiene monitoring has received limited attention in the academic literature. Graph-based anomaly detection addresses structural graph anomalies but not the temporal, multi-table character of enterprise hygiene state. Network intrusion benchmarks do not model identity hygiene or patch posture as evaluation axes (see [4], §2 for a survey of adjacent benchmarks).

D. Patch Management and Remediation Scheduling

NIST SP 800-40 Rev. 4 [7] frames enterprise patch management as a risk-based discipline requiring current, accurate asset and patch telemetry. CISA BOD 23-01 [8] mandates 14-day asset discovery and 72-hour patch data freshness cadences for federal agencies. These mandates implicitly encode hygiene requirements: fleets that fail them have stale telemetry, reducing the reliability of any signal-based prioritization. HygienePrio models this explicitly through the TelemetryFreshness dimension of HRS.

Remediation scheduling under capacity constraints has been studied as an optimization problem [3]. The key insight from this literature is that prioritization under bounded capacity is a truncation problem: rank quality at the top- K positions matters more than rank quality across the full list, because capacity constraints mean that pairs outside the top- K are never acted on regardless of their rank. This motivates Precision@ K as the primary evaluation metric.

III. Problem Formulation

A. Setting

Let F denote a fleet of hosts $H = \{h_1, \dots, h_N\}$ and let $C = \{c_1, \dots, c_M\}$ denote a set of disclosed CVEs. Let $V \subseteq H \times C$ be the set of applicable (host, CVE) pairs:

$(h, c) \in V$ if CVE c is applicable to host h (i.e., host h runs vulnerable software affected by c). The set V is derived from the patch state and vulnerability records tables.

Let K be the remediation capacity: the number of (host, CVE) pairs that a team can remediate within a single maintenance window. A prioritization method produces a ranked list R of $|V|$ pairs; the top K elements of R define the action set for the window.

B. Ground Truth

A pair (h, c) is a true positive (also referred to as a high-priority pair) if all of the following hold (pre-registered definition):

- 1) $\text{EPSS}(c) > 0.10$ — the CVE has non-trivial exploit likelihood.
- 2) $\text{HRS}(h) > \text{fleet 75th percentile}$ — the host is in the bottom quartile of hygiene posture.
- 3) $(h, c) \in V$ — the CVE is applicable to the host.

Condition 1 ensures the CVE is at meaningful risk of exploitation. Condition 2 ensures the host is a hygiene outlier rather than a well-managed endpoint. The conjunction ensures HygienePrio’s design goal — identifying high-exploit-likelihood CVEs on hygiene-poor hosts — has an operational ground truth against which to evaluate.

Note on circularity: The use of HRS in both the scorer (via $\text{HRS}(h)$) and the ground truth (via the $\text{HRS} > 75\text{th percentile}$ condition) creates a structural advantage for HygienePrio over baselines that do not use HRS. This is acknowledged and discussed in §9 (Threats to Validity). The ground truth definition is pre-registered and fixed; it is not modified post-hoc to favor any method.

C. Metrics

Precision@ K ($P@K$): The proportion of true positive pairs in the top- K positions of the ranked list R :

$$P@K = \frac{|\{(h, c) \in \text{top}_K(R) : (h, c) \text{ is true positive}\}|}{K}$$

Evaluated at $K = 50, 100, 250$.

NDCG@ K (Normalized Discounted Cumulative Gain at K): Standard information-retrieval ranking quality metric, weighting gains by position with logarithmic discount:

$$\text{NDCG@}K = \frac{\text{DCG@}K}{\text{IDCG@}K}$$

where $\text{DCG@}K = \sum_{i=1}^K \text{rel}_i / \log_2(i + 1)$, $\text{rel}_i \in \{0, 1\}$ is the relevance of the i -th ranked pair, and $\text{IDCG@}K$ is the DCG of the ideal ranking. Evaluated at $K = 50, 100, 250$.

Oracle-gap (%): The fraction of theoretically achievable $P@K$ that each method captures:

$$\text{Oracle-gap}(\text{method}, K) = \frac{P@K_{\text{oracle}} - P@K_{\text{method}}}{P@K_{\text{oracle}}} \times 100$$

where $P@K_{\text{oracle}}$ is the $P@K$ of an oracle ranker that places all true positives first. Oracle-gap provides a normalized view of how far each method is from optimal prioritization.

TABLE I
EEHDA table schema and role in HygienePrio (medium-scale fleet)

Table	Rows	Role in HygienePrio
users	1,000	AD user account attributes
computers/assets	830	Host inventory; maps hosts to users
endpoint_patch_state	830	Per-host patch compliance snapshot (PatchPosture source)
vulnerability_records	~3,500	Per-host CVE exposure (16 EPSS scores)
telemetry_freshness_log	varies	Per-host data freshness (TelemetryFreshness source)
groups/group_membership_events	65/~51	AD group membership (ADExposure source)
anomaly_labels	110	HygieneBench ground truth (informational only)

IV. Dataset and Synthetic Fleet

A. EEHDA Synthetic Fleet

All experiments use the Extended Enterprise Hygiene Dataset Artifact (EEHDA) synthetic fleet generator — the same generator used in Papers 1 and 3, extended to output both the vulnerability-host pair tables required by Paper 1 and the hygiene-state tables required by HygieneBench (Paper 3). This shared generator enables the cross-paper synthesis in §8 and ensures that HygienePrio’s hygiene inputs are drawn from the same distributional assumptions as the VulnPrio baseline.

The generator produces the following tables relevant to HygienePrio (see HygieneBench [4] for full schema):

Structural priors. Patch-lag distributions follow DBIR 2026 aggregate statistics (43-day mean for critical patches). CVE severity distributions follow NVD base score statistics. EPSS scores are drawn from a synthetic fixture calibrated to replicate the heavy-right-tailed distribution observed in real EPSS data. KEV membership is sampled at approximately 8% prevalence. Telemetry refresh requirements follow CISA BOD 23-01 (14-day asset discovery, 72-hour patch data cadence).

B. Seed Protocol

Thirty seeds are generated deterministically. Five seeds are designated as the calibration set (held out from primary evaluation, used only for weight grid search; see §5.4). The remaining 25 seeds constitute the evaluation set. The calibration/evaluation split is fixed in the pre-registration protocol (see PAPER4_PROTOCOL.md) and is not adjusted based on results.

C. Hygiene Dimensions

Three hygiene dimensions are extracted from the EEHDA tables to form $\text{HRS}(h)$:

Patch Posture (PatchPosture). Derived from `endpoint_patch_state`. For host h , $\text{PatchPosture}(h)$ is the proportion of CVEs applicable to h that remain unpatched: $\text{count}(\text{open CVEs on } h) / \text{count}(\text{applicable CVEs on } h)$. Higher values indicate greater patch debt. Fleet-wide, this

distribution is right-skewed: most hosts have low patch debt, but a tail of hosts accumulates substantial residual exposure. This tail is the primary target of HygienePrio prioritization.

AD Exposure (ADExposure). Derived from users, groups, and group membership events. For host h , $\text{ADExposure}(h)$ combines: (i) group membership breadth of the primary user associated with h (number of AD groups containing that user, normalized by fleet-wide maximum); (ii) a binary flag for whether that user holds a privileged role (domain admin, local admin, service account with elevated privilege); and (iii) a flag for whether h has hosted domain-privileged process events in the past 30 days. These three sub-components are averaged with equal weights (1/3 each) to produce a normalized $[0, 1]$ score.

Telemetry Freshness (TelemetryFreshness). Derived from `telemetry_freshness_log`. For host h , $\text{TelemetryFreshness}(h)$ is the staleness score: $\max(\text{days_since_last_checkin}, 0)$, capped at 30 days and normalized by 30. A host last seen 15 days ago receives a score of 0.50; a host last seen 30+ days ago receives 1.0. Higher staleness = less visibility = higher hygiene risk weight. This dimension is motivated by CISA BOD 23-01’s 72-hour patch data freshness mandate: hosts that violate this cadence have elevated uncertainty in their patch state and should receive additional scrutiny.

D. CVE Fixture and EPSS Scores

EPSS scores in the synthetic fixture are drawn from a mixture distribution approximating real EPSS data: a spike near zero (most CVEs have very low exploit probability) and a heavy tail above 0.10. Approximately 12% of CVEs in each seed have $\text{EPSS} > 0.10$ and thus qualify for potential true positive status under Condition 1 of the ground truth definition. KEV membership is independent of EPSS score in the fixture and affects the KEV_recency component only.

E. Connection to HygieneBench

HygieneBench (Paper 3) defined 12 anomaly classes (AH-01 through AH-12) including stale privileged accounts (AH-01), dormant account reactivation (AH-02), endpoint coverage gaps (AH-06), patch noncompliance clusters (AH-08), and telemetry missingness (AH-10 through AH-12). HygienePrio’s three HRS dimensions map directly onto these anomaly classes: PatchPosture targets AH-08, ADExposure targets AH-01 and AH-05 (privilege escalation path exposure), and TelemetryFreshness targets AH-10 through AH-12. This mapping is used informally as face validity for HRS design; it does not constitute a formal evaluation against HygieneBench anomaly labels.

V. HygienePrio Methodology

A. Hygiene Risk Score (HRS)

$\text{HRS}(h)$ is a normalized, weighted combination of the three hygiene dimensions defined in §4.3:

$$\begin{aligned} \text{HRS}(h) = & w_1 \times \text{PatchPosture}(h) \\ & + w_2 \times \text{ADExposure}(h) \\ & + w_3 \times \text{TelemetryFreshness}(h) \end{aligned} \quad (1)$$

Dimension weights (w_1, w_2, w_3) are non-negative and sum to 1.0. They are not calibrated by the grid search (which calibrates the scorer-level weights $\alpha, \beta, \gamma, \delta$); instead, dimension weights are fixed based on the pre-registration protocol defaults: $w_1 = 0.5$, $w_2 = 0.3$, $w_3 = 0.2$. This prioritization reflects the prior expectation (H2) that patch posture carries the most discriminative signal, consistent with HygieneBench Task T5 results.

Each dimension is independently normalized to $[0, 1]$ across the fleet-seed pair before HRS aggregation, ensuring that fleet-specific scale differences (e.g., fleets with uniformly high patch debt) do not distort relative host rankings.

HRS calibration note. Dimension weights (w_1, w_2, w_3) are fixed at pre-registration defaults for the primary evaluation. Sensitivity to dimension weights is explored in the ablation (§7.2) by setting individual weights to zero. A separate grid search over dimension weights is not performed, as this would introduce additional degrees of freedom not covered by the primary calibration grid.

B. KEV Recency Weight

$\text{KEV_recency}(c)$ assigns higher priority to CVEs recently added to the CISA KEV catalog, under the rationale that recently catalogued exploited CVEs represent more active threat vectors:

$$\text{KEV-recency}(c) = \begin{cases} e^{-\lambda \cdot d_{\text{kev}}(c)} & c \in \text{KEV} \\ 0 & c \notin \text{KEV} \end{cases} \quad (2)$$

where $d_{\text{kev}}(c)$ is days since KEV catalog entry for CVE c .

The decay constant $\lambda = 0.05$ is fixed at the pre-registration default (corresponding to a half-life of approximately 14 days — matching the CISA BOD 23-01 asset discovery cadence). The sensitivity of results to λ is explored informally but not reported as a separate ablation condition.

For CVEs not in KEV (approximately 92% of the fixture), $\text{KEV_recency}(c) = 0$, and those pairs are prioritized on EPSS and HRS alone. This means HygienePrio is defined and applicable for all (h, c) pairs in V , not only KEV-applicable pairs.

C. HygienePrio Scorer

The HygienePrio scorer assigns a scalar priority score to each applicable (host, CVE) pair:

$$\begin{aligned} S(h, c) = & \alpha \cdot \text{EPSS}(c) + \beta \cdot \text{HRS}(h) \\ & + \gamma \cdot \text{KEV-recency}(c) \\ & + \delta \cdot (\text{EPSS}(c) \cdot \text{HRS}(h)) \end{aligned} \quad (3)$$

The four terms have distinct roles:

- $\alpha \times \text{EPSS}(c)$: Exploit likelihood contribution. Ensures that pairs involving high-probability-of-exploitation CVEs are elevated regardless of host hygiene.
- $\beta \times \text{HRS}(h)$: Host hygiene contribution. Elevates pairs on hygiene-poor hosts even when EPSS is moderate.
- $\gamma \times \text{KEV_recency}(c)$: Recency-weighted confirmed exploitation signal. Boosts recently catalogued KEV CVEs.
- $\delta \times (\text{EPSS}(c) \times \text{HRS}(h))$: Interaction term. Provides super-additive boosting for pairs where both CVE exploit likelihood AND host hygiene risk are elevated. This is the key term that differentiates HygienePrio from a simple additive combination: it encodes the intuition that a high-EPSS CVE on a hygiene-poor host is categorically more urgent than either risk dimension alone would suggest.

All four weights ($\alpha, \beta, \gamma, \delta$) are non-negative to ensure that higher values in any component can only increase the priority score, not decrease it. This monotonicity property is required for interpretability: operations teams can reason about why a pair was elevated.

D. Weight Calibration

Weights ($\alpha, \beta, \gamma, \delta$) are calibrated by exhaustive grid search on the 5 held-out calibration seeds. The calibration objective is mean P@50 across the 5 seeds. The search grid is:

- $\alpha \in \{0.3, 0.5, 0.7, 1.0\}$
- $\beta \in \{0.1, 0.3, 0.5, 0.7\}$
- $\gamma \in \{0.0, 0.1, 0.3, 0.5\}$
- $\delta \in \{0.0, 0.1, 0.2, 0.3\}$

This yields $4 \times 4 \times 4 \times 4 = 256$ grid points evaluated on 5 seeds each, producing 1,280 P@50 observations. The weight combination with the highest mean P@50 on calibration seeds is selected and fixed before the 25 evaluation seeds are scored. No weight adjustment is made after observing evaluation results.

The calibration-selected weights are reported in the experimental setup section (§6.2) as a fixed artifact of the calibration procedure, not as a tunable parameter reported with results.

E. Ranked List Generation

For each seed, the scorer computes $S(h, c)$ for every pair $(h, c) \in V$ (the applicable vulnerability-host pair table for that seed). Pairs are sorted descending by $S(h, c)$. Ties are broken by $\text{EPSS}(c)$ descending, then by CVE ID lexicographic order for determinism. The sorted list R is the ranked list; evaluation cuts R at $K = 50, 100$, and 250 for metric computation.

F. Relationship to EPSS-Only Baseline

The EPSS-only baseline ranks (h, c) pairs by $\text{EPSS}(c)$ descending, with ties broken by CVSS base score. Under this baseline, all pairs involving the same CVE receive

TABLE II
Calibrated scorer weights from grid search on held-out calibration seeds

Parameter	Calibrated Value
α (EPSS weight)	0.7
β (HRS weight)	0.5
γ (KEV_recency weight)	0.1
δ (interaction weight)	0.2

identical rankings, regardless of which host carries the CVE. HygienePrio breaks this tie-structure via $\text{HRS}(h)$: among pairs sharing a CVE, those on hygiene-poor hosts are elevated. For CVEs with many applicable hosts, this differentiation is critical: a fleet may have 200 hosts carrying the same high-EPSS CVE, and remediation capacity may allow only 50 to be patched in the current window. HygienePrio’s host-level tiebreaking directly addresses this case.

VI. Experimental Setup

A. Evaluation Infrastructure

All experiments are implemented in Python 3.11 using NumPy 1.26, Pandas 2.1, and scikit-learn 1.4. Randomness in baseline methods (Random) is seeded by the fleet seed, ensuring reproducibility. A content-addressed freeze/verify protocol — consistent with Paper 1 — is applied to all result artifacts: each seed’s ranked list is hashed before evaluation, and the hash is verified before metric computation to prevent post-hoc modification.

B. Calibrated Weights

Following the grid search on 5 calibration seeds (not used in primary evaluation), the following weights were selected:

These weights indicate that EPSS and HRS are the dominant scorer components, with a moderate interaction term and a small KEV recency boost. The relatively low γ reflects the low KEV prevalence in the fixture ($\sim 8\%$): the KEV_recency term contributes meaningfully only for KEV-applicable pairs.

C. Evaluation Procedure

For each of the 25 evaluation seeds:

- 1) Generate the EEHDA fleet tables deterministically from the seed.
- 2) Compute $\text{HRS}(h)$ for each host using pre-registered dimension weights ($w_1 = 0.5$, $w_2 = 0.3$, $w_3 = 0.2$).
- 3) Compute $\text{KEV_recency}(c)$ for each CVE using fixed $\lambda = 0.05$.
- 4) Score all $(h, c) \in V$ using calibrated weights.
- 5) Generate ranked list R by sorting descending by $S(h, c)$.
- 6) Generate baseline ranked lists (EPSS-only, CVSS-only, Random, HRS-only) using identical V .
- 7) Compute ground truth labels using the pre-registered definition (§3.2).

TABLE III
Baseline and ablation methods evaluated

Method	Description
EPSS-only	Rank by EPSS(c) descending; primary comparison
CVSS-only	Rank by CVSS base score descending
Random	Uniform random (seed-fixed)
HRS-only	Rank by $\text{HRS}(h)$ descending; tests host hygiene without CVE signal
HygienePrio-full	Full scorer with calibrated weights
HygienePrio-noInteraction	$\delta = 0$ (additive only; tests interaction term contribution)
HygienePrio-noPatch	$w_1 = 0$ (patch posture removed from HRS)
HygienePrio-noAD	$w_2 = 0$ (AD exposure removed from HRS)
HygienePrio-noFreshness	$w_3 = 0$ (telemetry freshness removed from HRS)

- 8) Compute P@K , NDCG@K , Oracle-gap for $K = 50, 100, 250$ for all methods.
- 9) Hash and verify result artifacts.

D. Baselines

E. Reporting Convention

All metrics are reported as mean $\pm$ 95% bootstrap confidence interval (BCa method, 10,000 resamples) across 25 evaluation seeds. No null hypothesis significance testing is performed; evidence is based on BCa CI non-overlap between HygienePrio-full and EPSS-only. Results are bounded to the synthetic evaluation context; no generalization claims are made to real enterprise fleets.

VII. Results

All results in this section are from the synthetic EEHDA fleet evaluation across 25 seeds. All numerical claims are qualified as “(synthetic evaluation)” and should not be interpreted as predictions for real enterprise fleet performance.

A. Precision@K: All Methods Across $K = 50, 100, 250$

Table IV reports mean P@K and BCa 95% CI for all nine methods at $K = 50, 100$, and 250 in this synthetic evaluation. The following observations emerge from the results.

HygienePrio-full vs. EPSS-only. HygienePrio-full achieves a mean P@50 of 0.509 compared with EPSS-only’s 0.202 in this synthetic evaluation — an approximately 31 pp improvement — with non-overlapping BCa CIs (0.480–0.542 vs. 0.174–0.236). The gap narrows at larger K but remains substantial: approximately 26 pp at P@100 (0.458 vs. 0.199) and 21 pp at P@250 (0.420 vs. 0.215). This pattern is consistent with RQ3: the hygiene signal is most discriminative at the tightest capacity constraint ($K = 50$), where the scorer must be most selective, and remains large but attenuated at larger K .

H1 assessment. The observed improvement of approximately 31 pp at P@50 (synthetic evaluation) substantially

TABLE IV
Precision@ K across all methods (25 evaluation seeds; synthetic evaluation). BCa 95% CI, 10,000 resamples. Frozen results from primary_results_v1/primary_results.csv (225 rows: 25 seeds $\times$ 9 methods).

Method	P@50 mean (95% CI)	P@100 mean (95% CI)	P@250 mean (95% CI)
HygienePrio-full	0.509 (0.480–0.542)	0.458 (0.441–0.474)	0.420 (0.408–0.432)
HygienePrio-noFreshness	0.490 (0.463–0.528)	0.446 (0.426–0.463)	0.411 (0.398–0.422)
HygienePrio-noInteraction	0.482 (0.454–0.515)	0.445 (0.428–0.462)	0.417 (0.405–0.430)
HygienePrio-noAD	0.424 (0.395–0.460)	0.379 (0.362–0.398)	0.370 (0.357–0.382)
HygienePrio-noPatch	0.312 (0.283–0.343)	0.289 (0.270–0.309)	0.284 (0.273–0.294)
HRS-only	0.288 (0.263–0.310)	0.284 (0.265–0.304)	0.282 (0.271–0.291)
EPSS-only	0.202 (0.174–0.236)	0.199 (0.185–0.218)	0.215 (0.205–0.226)
CVSS-only	0.056 (0.044–0.069)	0.056 (0.046–0.065)	0.057 (0.052–0.061)
Random	0.048 (0.039–0.056)	0.062 (0.054–0.071)	0.061 (0.055–0.067)

exceeds the pre-registered H1 threshold of ≥ 5 pp, supporting H1 in the synthetic evaluation context. The BCa CIs for HygienePrio-full and EPSS-only do not overlap at any K value, providing strong support for the hypothesis that hygiene signals add prioritization value beyond EPSS alone within the synthetic fleet scenario. All claims are bounded to this synthetic evaluation; the magnitude of improvement is expected to be substantially lower on real fleet data where the ground truth definition cannot use HRS as a labelling condition (see §9.1).

EPSS-only vs. CVSS-only. Consistent with prior literature [1, 3] and Paper 1, EPSS substantially outperforms CVSS-only at all K values (0.202 vs. 0.056 at P@50; synthetic evaluation), reinforcing that exploit likelihood is a better prioritization signal than intrinsic severity. This replication of the Paper 1 finding on a different metric (P@ K vs. EHD) provides internal consistency.

HRS-only vs. EPSS-only. HRS-only (host hygiene without CVE signal) achieves 0.288 at P@50 versus EPSS-only’s 0.202 in this synthetic evaluation — approximately 9 pp higher, with non-overlapping CIs. However, HygienePrio-full (0.509) substantially outperforms HRS-only (0.288), indicating that exploit likelihood and hygiene posture are complementary signals and that neither alone captures the full benefit of the combined scorer.

B. Ablation: Hygiene Dimension Contributions

Table V presents the ablation results, comparing HygienePrio-full with three leave-one-dimension-out variants. Results are for P@50 in this synthetic evaluation.

H2 assessment. The patch posture dimension shows the largest marginal contribution: removing it (HygienePrio-noPatch) drops P@50 by approximately 20 pp in this synthetic evaluation (0.509 $\rightarrow$ 0.312), with non-overlapping BCa CIs, strongly supporting H2. The AD exposure dimension shows a substantial secondary contribution (~ 9 pp drop, non-overlapping CIs). Telemetry freshness shows the smallest contribution (~ 2 pp drop, overlapping CIs suggesting marginal discriminative power in the synthetic fleet). This result is consistent with HygieneBench Task T5’s finding that patch-vulnerability hygiene carries the most discriminative signal among hygiene dimensions.

The dimension ordering (patch posture $>$ AD exposure $\gg$ freshness) in this synthetic evaluation suggests that op-

TABLE V
Ablation — P@50 impact of removing each hygiene dimension (synthetic evaluation). Ablation uses fixed ground-truth labels (HRS from calibrated weights); only scorer’s HRS input changes.

Condition	P@50 (95% CI)	Drop	CI overlap?
Full model	0.509 (0.480–0.542)	—	—
noPatch ($w_1=0$)	0.312 (0.283–0.343)	–20 pp	No
noAD ($w_2=0$)	0.424 (0.395–0.460)	–9 pp	No
noFreshness ($w_3=0$)	0.490 (0.463–0.528)	–2 pp	Yes

erations teams seeking to deploy a simplified HygienePrio variant should prioritize patch posture instrumentation first, AD group exposure tracking second, and telemetry freshness monitoring last — at least in the synthetic fleet scenario modeled here.

C. Interaction Term Analysis

Comparing HygienePrio-full with HygienePrio-noInteraction reveals approximately 3 pp improvement at P@50 from including the interaction term (EPSS $\times$ HRS) in this synthetic evaluation (0.509 vs. 0.482). The BCa CIs overlap substantially (0.480–0.542 vs. 0.454–0.515), suggesting the interaction term’s contribution is marginal under the synthetic evaluation conditions. At P@100 and P@250 the difference narrows further (~ 1 pp). The interaction term’s modest contribution likely reflects the synthetic fixture’s EPSS distribution: the truly high-EPSS AND high-HRS pair conjunctions are relatively rare (~ 10 – 12% of applicable pairs per seed), limiting opportunities for the interaction term to add discriminative value.

Per the pre-registration stop rule, if HygienePrio-noInteraction achieves P@ K within 1 pp of HygienePrio-full for all K , the interaction term would be declared uninformative. At P@50 the difference exceeds 1 pp (3 pp), so the interaction term is retained in the reported full model. However, the overlapping CIs mean this finding should be treated as equivocal: the interaction term likely does not materially change prioritization decisions in this synthetic fleet context.

TABLE VI
Oracle-gap (%) at $K = 50$ by method (synthetic evaluation; BCa 95% CI)

Method	Oracle-gap (95% CI)	P@50 captured
HygienePrio-full	49.1% (45.6–51.8%)	~51% of oracle
EPSS-only	79.8% (76.3–82.6%)	~20% of oracle
CVSS-only	94.4% (93.0–95.5%)	~6% of oracle
Random	95.2% (94.2–96.0%)	~5% of oracle

D. Oracle-Gap Analysis

The oracle-gap analysis indicates that even HygienePrio-full captures approximately 51% of theoretically achievable precision at $K = 50$ in this synthetic evaluation, leaving substantial room for improvement. The gap between HygienePrio-full and the oracle (49.1%) reflects both the inherent difficulty of the ranking problem and the residual uncertainty in hygiene signals: among hygiene-poor hosts with similar HRS values, the scorer cannot further discriminate which specific CVE-host pair is the highest-priority target. At $K = 50$, with approximately 185–200 true positives per seed (synthetic evaluation), the maximum achievable P@50 is 1.0 (oracle), and HygienePrio-full achieves 0.509. The 49.1% oracle gap is substantially smaller than EPSS-only’s 79.8% gap, confirming that hygiene signals materially reduce the distance from optimal prioritization in this synthetic context.

E. Summary of Main Findings

In this synthetic evaluation, the results suggest the following:

- 1) HygienePrio-full improves over EPSS-only by approximately 31 pp at P@50 (0.509 vs. 0.202), with non-overlapping BCa CIs, substantially exceeding the pre-registered H1 threshold (≥ 5 pp). Improvement is 26 pp at P@100 and 21 pp at P@250. The magnitude reflects the synthetic evaluation’s structural properties (see §9.1 circularity note).
- 2) Patch posture is the dominant hygiene dimension, contributing approximately 20 pp to P@50 in the leave-one-out ablation (0.509 $\rightarrow$ 0.312 without patch posture), with non-overlapping CIs, strongly supporting H2.
- 3) AD exposure is a substantial secondary contributor, reducing P@50 by ~ 9 pp when removed (0.509 $\rightarrow$ 0.424), with non-overlapping CIs.
- 4) The interaction term and telemetry freshness are marginal in this synthetic evaluation: both show overlapping CIs with the full model, with contributions of ~ 3 pp and ~ 2 pp respectively. The pre-registration stop rule is not triggered at P@50 for the interaction term (3 pp $>$ 1 pp threshold), so both are retained in the full model.

- 5) HRS-only outperforms EPSS-only by ~ 9 pp (0.288 vs. 0.202), but the combination (HygienePrio-full, 0.509) substantially outperforms either signal alone, confirming that exploit likelihood and hygiene posture are complementary.
- 6) Oracle gap remains substantial: HygienePrio-full captures $\sim 51\%$ of theoretically achievable P@50, versus $\sim 20\%$ for EPSS-only, indicating both that hygiene signals provide meaningful benefit and that significant room for improvement remains.

VIII. Discussion

A. Why Hygiene Signals Help Where CVE-Level Features Alone Did Not

Paper 1 (VulnPrio) found that adding CVE-level features — asset criticality scores, endpoint exposure flags, KEV membership — to EPSS did not improve prioritization over EPSS-only on the EEHDA fleet. The explanation offered in Paper 1 was that uncalibrated weights on synthetic fixtures could not extract signal from these features. HygienePrio’s results in this synthetic evaluation suggest an alternative or complementary explanation: the features added in Paper 1 were primarily CVE-level or static host-role features, while the missing signal was dynamic, telemetry-derived host-level hygiene posture.

The structural difference is important. Knowing that a host is a “domain controller” (asset criticality signal from Paper 1) provides some risk context, but it does not distinguish between a well-managed domain controller with current patches and telemetry, and a neglected domain controller with 60% unpatched CVE debt, stale telemetry, and over-privileged group memberships. HRS captures this distinction; asset criticality does not.

This observation is consistent with HygieneBench’s (Paper 3) finding that ML methods add meaningful signal on patch-vulnerability hygiene (T5) and group-membership drift (T2) — precisely the dimensions that HRS encodes. The signal is present in the hygiene telemetry; the challenge is surfacing it in a form suitable for prioritization scoring.

B. Cross-Paper Synthesis

The three papers form a methodological sequence:

- 1) Paper 1 (VulnPrio): Established the prioritization problem, EEHDA fleet, and the null result that CVE-level multi-factor models do not improve over EPSS on EHD metric. Contribution: reproducible benchmark and honest null.
- 2) Paper 3 (HygieneBench): Established that host-level hygiene signals (patch posture, AD drift, telemetry staleness) carry discriminative structure detectable from synthetic fleet telemetry, though 86.2% of ML configurations fail to outperform simple rules. Contribution: hygiene anomaly benchmark and failure-aware evaluation.

- 3) Paper 4 (HygienePrio): Integrates the lessons: hygiene signals (from Paper 3) added to the EPSS-weighted prioritization framework (from Paper 1) suggest measurable improvement in P@K (synthetic evaluation). Contribution: first cross-domain integration of exploit likelihood and hygiene posture for remediation ordering.

This sequence illustrates a research methodology of building on honest null results. Paper 1’s null did not indicate that the problem is unsolvable; it indicated that a particular feature set was insufficient. Paper 3 identified a feature set with discriminative potential. Paper 4 operationalizes that identification. Future work (Section 11) could test Paper 4’s claim on real fleet data.

C. Practical Implications (Synthetic-Only)

If the synthetic-evaluation results generalize — which requires external validation on real fleet data not performed here — then operations teams using EPSS-only prioritization may be systematically underweighting the risk from hygiene-poor hosts. A host with moderate EPSS CVEs but severe patch debt, stale telemetry, and broad AD exposure may be a higher-priority target than a well-managed host carrying a high-EPSS CVE.

The ablation results suggest that patch posture is the highest-value hygiene dimension for prioritization. Teams with limited instrumentation capacity should prioritize patch posture tracking before more complex hygiene signals such as AD exposure breadth or telemetry freshness monitoring. This ordering is consistent with the CISA BOD 23-01 mandate hierarchy, which prioritizes patch data freshness (72-hour cadence) as the foundational telemetry requirement.

D. Limitations

Synthetic data. All results are from a synthetically generated fleet using structural priors from public sources (DBIR, NVD, CISA BOD). The synthetic fleet cannot capture the full heterogeneity of real enterprise environments: vendor-specific patch behaviors, organizational policy exceptions, legacy asset configurations, and attacker behavior patterns that differ from synthetic threat models. Results should not be interpreted as predictions for real fleet prioritization without external validation.

Ground truth circularity. HygienePrio’s ground truth definition includes $HRS > 75\text{th percentile}$ as a condition (§3.2). This creates a structural advantage for HygienePrio-full and variants that incorporate HRS over baselines (EPSS-only, CVSS-only, Random) that do not. The pre-registration fix of this definition before evaluation prevents post-hoc optimization, but the circularity is an inherent design tension. Future work could use independent ground truth (e.g., actual exploitation events in real fleet data) to evaluate HygienePrio without this circularity.

Calibration on synthetic data. Weights calibrated on synthetic seeds may not transfer to real fleet data, where

distributional assumptions (patch-lag priors, EPSS score distribution, KEV prevalence) may differ substantially.

Scorer linearity. The HygienePrio scorer is a linear combination with one interaction term. More complex non-linear relationships between hygiene dimensions and remediation priority may exist in real fleets that a linear scorer cannot capture.

IX. Threats to Validity

A. Internal Validity

Synthetic data generation assumptions. The EEHDA fleet generator uses structural priors (DBIR patch-lag statistics, NVD severity distributions) that represent population-level aggregates, not individual fleet characteristics. If real fleets deviate substantially from these priors — for example, if patch debt is systematically correlated with host criticality in a way not modeled by the generator — results may not replicate.

Ground truth definition. The pre-registered ground truth definition ($EPSS > 0.10$, $HRS > 75\text{th percentile}$, applicable CVE) is operationally reasonable but not validated against actual exploitation events. Different ground truth definitions would produce different P@K values for all methods; the magnitude of HygienePrio’s advantage over EPSS-only is sensitive to the threshold choices (particularly the 75th percentile cutoff for HRS).

Calibration leakage. Although calibration and evaluation seeds are strictly separated, the 5 calibration seeds and 25 evaluation seeds are generated by the same generator from adjacent seed values. If the generator has strong auto-correlation across adjacent seeds, the calibration/evaluation separation may be partially compromised. The pre-registration protocol fixes this separation before results are observed.

B. External Validity

Generalizability to real enterprise fleets. The synthetic fleet cannot replicate the diversity of real enterprise environments. All results are bounded to the synthetic evaluation context. Claims about real-fleet performance would require studies on real fleet data with appropriate institutional approvals and privacy protections.

Generalizability across sectors. The EEHDA generator is calibrated for government-shaped public-sector fleet characteristics (following Paper 1). Commercial enterprise fleets, healthcare organizations, and critical infrastructure environments may have substantially different hygiene posture distributions, making the specific weight calibration inapplicable.

C. Construct Validity

HRS validity as a proxy for real risk. The Hygiene Risk Score is a constructed proxy for host-level hygiene risk, not a validated measure of actual exploitation vulnerability. The assumption that a host with high HRS is genuinely higher-risk than one with low HRS requires empirical

validation against real exploitation outcomes, which is beyond scope here.

P@ K as a remediation metric. Precision@ K assumes that true positive pairs are equally valuable. In real operations, some (host, CVE) pairs may be substantially more consequential than others (e.g., domain controllers vs. user workstations), and a metric that weights pairs by severity or business impact might yield different method rankings.

D. Statistical Considerations

All comparisons use descriptive statistics with BCa bootstrap CIs across 25 seeds. No NHST p-values are computed; evidence is based on CI non-overlap. With 25 seeds, the bootstrap CIs have limited resolution: small differences ($< \sim 3$ pp) are unlikely to be distinguishable from seed-to-seed variation. All reported differences of ≥ 6 pp are accompanied by non-overlapping 95% CIs and are treated as substantive evidence in the synthetic-evaluation context. Differences below this threshold (notably the HRS-only vs. EPSS-only comparison) are treated as equivocal.

X. Related Work

This section supplements §2 with additional related work.

Risk-based vulnerability management (RBVM). Commercial RBVM platforms (Tenable Lumin, Qualys TruRisk, Rapid7 InsightVM) combine EPSS, CVSS, threat intelligence, and asset context in proprietary scoring models. These systems address the same problem as HygienePrio but are closed and not independently reproducible. No comparison claims are made against commercial RBVM tools.

Machine-learning vulnerability prioritization. Jacobs et al. [1] developed EPSS as a supervised learning model on NVD and threat intelligence features. HygienePrio differs from these in focusing on the host dimension rather than CVE-level features.

Identity and access management risk. AD-exposure-aware risk scoring has been proposed in the context of lateral movement risk assessment. HygienePrio incorporates AD exposure as one dimension of HRS rather than as a standalone risk signal, consistent with the multi-dimensional hygiene framing of HygieneBench.

Telemetry freshness and observability. The requirement for current asset and patch telemetry is mandated by CISA BOD 23-01 [8]. HygienePrio operationalizes telemetry freshness as a host-level risk amplifier, encoding the intuition that a host we cannot see clearly is riskier to deprioritize.

XI. Conclusion

This paper presented HygienePrio, a cyber-hygiene-augmented EPSS-weighted scoring framework for (host,

CVE) pair prioritization in capacity-constrained vulnerability remediation. HygienePrio integrates a three-dimensional Hygiene Risk Score (HRS) — covering patch posture, AD exposure state, and telemetry freshness — into an EPSS-weighted scorer with an explicit interaction term, calibrated by grid search on held-out seeds.

In a pre-registered synthetic evaluation across 25 fleet seeds of the EEHDA synthetic fleet, HygienePrio achieves mean Precision@ K of 0.509/0.458/0.420 at $K = 50/100/250$, compared with EPSS-only’s 0.202/0.199/0.215 — approximately 31, 26, and 21 pp improvements respectively (synthetic evaluation; non-overlapping BCa 95% CIs at all K values). Patch posture emerges as the dominant hygiene dimension, contributing approximately 20 pp to P@50 in leave-one-out ablation; AD exposure contributes ~ 9 pp; telemetry freshness contributes ~ 2 pp (marginal, overlapping CIs). The EPSS $\times$ HRS interaction term contributes approximately 3 pp with overlapping CIs, suggesting equivocal evidence for super-additive benefit in this synthetic fleet.

These results represent a synthesis of the research sequence established by Paper 1 (VulnPrio) and Paper 3 (HygieneBench). Paper 1’s null finding — that CVE-level multi-factor models do not improve over EPSS — suggested the missing signal was host-level rather than CVE-level. Paper 3’s positive findings on patch-vulnerability hygiene and AD group-membership drift anomaly detection suggested that host-level hygiene signals carry discriminative structure. HygienePrio integrates these lessons into a prioritization scorer that shows positive empirical results in the synthetic evaluation context.

Scope limitations. All results are from a synthetic fleet evaluation and should not be generalized to real enterprise fleet performance without external validation. The ground truth definition incorporates HRS, creating a structural advantage for HygienePrio that independent evaluation on real exploitation outcome data could remove.

Future work. Paper 5 of this research sequence could evaluate HygienePrio on real, appropriately anonymized fleet telemetry data from an organization with suitable data governance and IRB/ethics review, testing whether the synthetic-evaluation positive finding generalizes. Additional directions include: (i) extending HRS with network-layer exposure signals (firewall rule coverage, internet-facing service flags); (ii) adapting HygienePrio to continuous scoring rather than window-based scheduling; and (iii) exploring non-linear scorer architectures (gradient-boosted rankers) trained on historical remediation outcome data.

References

- [1] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, “Exploit prediction scoring system (EPSS),” *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 14:1–14:17, 2021.
- [2] J. Jacobs, S. Romanosky, I. Sahi, and W. Baker, “Improving vulnerability remediation through better exploit prediction,” *Journal of Cybersecurity*, vol. 6, no. 1, 2020, [VERIFY at camera-ready] — confirm journal, volume, and year.

- [3] Harshavardhan Malla, “Context-aware vulnerability prioritization for government endpoint fleets: Integrating exploit intelligence, asset criticality, and endpoint telemetry,” 2026, manuscript on file; pre-print / submission reference to be added at camera-ready. [VERIFY at camera-ready].
- [4] —, “HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection across identity, endpoint, and patch telemetry,” 2026, manuscript on file; pre-print / submission reference to be added at camera-ready. [VERIFY at camera-ready].
- [5] CISA, “Known exploited vulnerabilities (KEV) catalog,” U.S. Cybersecurity and Infrastructure Security Agency, accessed May 2026. [Online]. Available: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [6] —, “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: <https://www.cisa.gov/binding-operational-directive-22-01>
- [7] NIST, “Guide to enterprise patch management planning: Preventive maintenance for technology,” National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-40r4>
- [8] CISA, “Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks,” U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: <https://www.cisa.gov/binding-operational-directive-23-01>